

Secure Enterprise Network with Site-to-Site VPN, Client Access, and Centralized Splunk Logging

1. Executive Summary & Objective

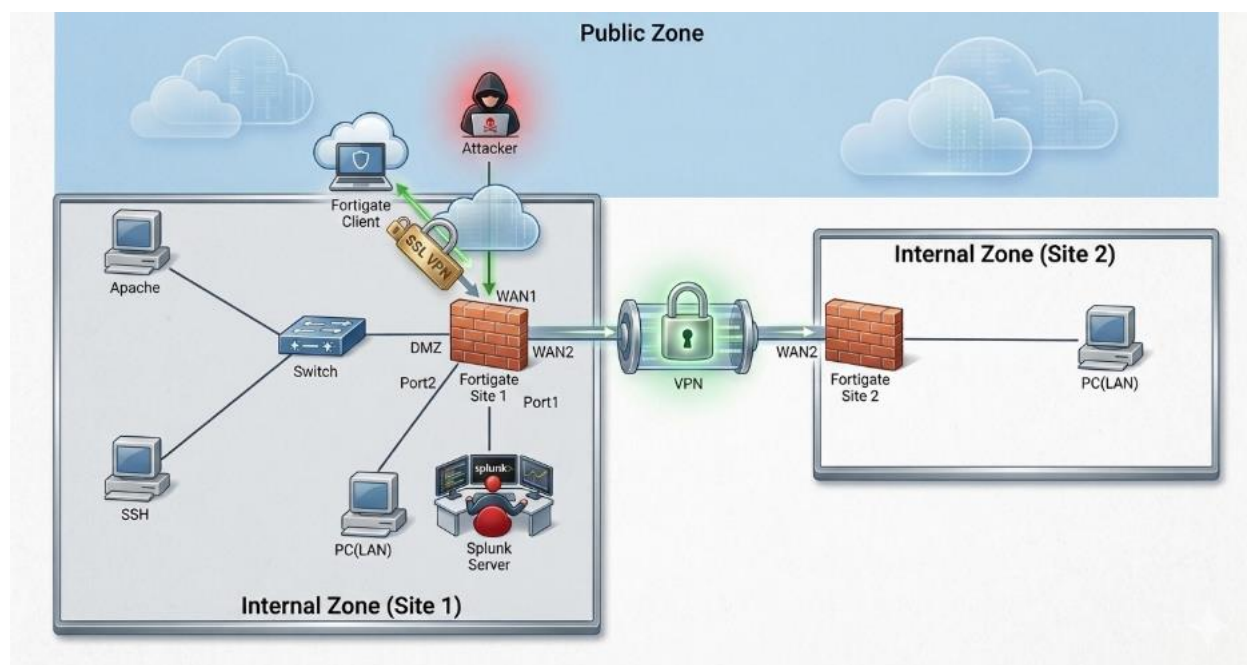
In modern enterprise environments, maintaining robust visibility, secure inter-site communication, and rigorous boundary controls are fundamental pillars of defense-in-depth architecture. This technical report details the end-to-end design and engineering execution of a multi-site enterprise network infrastructure. Built to satisfy rigorous compliance and operation resilience metrics, the architecture links a main headquarters branch (Site 1) to a secondary branch office (Site 2), provides fully authenticated client-based remote access for off-site personnel, and aggregates telemetry data into a centralized Security Information and Event Management (SIEM) pipeline.

The primary operational objectives realized during this engagement include:

- **Secure Multi-Site Connectivity:** Architecting and establishing an encrypted Site-to-Site IPsec VPN tunnel across simulated untrusted public WAN infrastructure using FortiGate enterprise firewalls.
- **Authenticated Remote Workforce Mobility:** Configuring and operationalizing an SSL-VPN Client-Based portal located in the public zone to allow remote workers safe passage into secure internal segments.
- **Comprehensive Security Monitoring:** Constructing a continuous ingestion framework feeding log data from corporate network firewalls, Linux servers, Apache web platforms, and OpenSSH endpoints into a centralized Splunk Enterprise indexing server.
- **Threat Validation & Analysis:** Executing real-world cyber threat simulations—specifically, automated Nmap reconnaissance mapping and high-velocity SSH brute force credential attacks—to validate rule correlation and train real-time dashboard notification alerts.

2. Network Infrastructure & Topology Architecture

The underlying physical design separates functional entities into strictly bound network security zones, preventing unauthorized lateral movement and forcing all traffic through explicit stateful firewall inspection rules.



2.1 Subnetting and Segmentation Schema

An IP addressing matrix was calculated using Classless Inter-Domain Routing (CIDR) block allocations to provide granular segmentation while reserving appropriate overhead for host expansion. The address architecture maps directly to specific zone interfaces:

Zone Designation	Network Subnet (CIDR)	Gateway Interface	Primary Hosted Services
Site 1: Internal LAN	192.168.10.0/24	FortiGate-S1 (Port2)	Internal Engineering Stations, Core Workstations
Site 1: DMZ	192.168.2.0/24	FortiGate-S1 (DMZ)	Public Apache Web Server, OpenSSH Server Appliance
Site 1: Management	192.168.1.0/24	FortiGate-S1 (Port3)	Splunk Indexer Engine, PC Administrator Console Terminal
Site 2: Internal LAN	192.168.20.0/24	FortiGate-S2 (Internal)	Branch Workstations, Local Storage Resources, PC (LAN)
Public Zone (WAN Fabric)	192.168.64.0/24	Untrusted Cloud	Kali Linux Attacker Device, FortiGate Remote SSL-VPN Client Portal

2.2 Core Component Configurations

- FortiGate Site 1 (Headquarters Firewall):** Acts as the main security gateway. It maintains a primary interface out to the public zone (WAN1), an IPsec termination interface (WAN2), a dedicated DMZ interface handling internet-exposed workloads, a local LAN switch leg, and a hardened management port routing server telemetry.

- **FortiGate Site 2 (Branch Office Firewall):** Handles edge enforcement for the remote branch office, running stateful packet filtration and terminating the corresponding Site-to-Site IPsec tunnel to bridge internal subnets seamlessly.
- **Splunk Indexer / Server Node:** Strategically situated within the highly controlled 192.168.1.0/24 Management Subnet to isolate raw event store mechanisms from standard user land vulnerabilities.

3. Advanced Virtual Private Network (VPN) Engineering

Secure transit pathways across public infrastructure utilize two distinct cryptographic deployment patterns configured on FortiGate appliances. This design addresses both point-to-point branch office plumbing and ad-hoc user-to-office remote access, backed by explicit stateful inspection firewall policies.

3.1 Site-to-Site IPsec VPN Implementation

A persistent, policy-driven network layer tunnel bridges Site 1 and Site 2 using standard Internet Protocol Security (IPsec) extensions. The tunnels were engineered using the FortiGate static wizard platform to map point-to-point transit paths directly over the untrusted public zone interfaces (wan2).

3.1.1 Cryptographic and Tunnel Parameters

To ensure data confidentiality, integrity, and replay protection, the cryptographic phase proposals negotiate multiple security parameters to maintain an optimized security posture:

- **Gateway Mappings:** Site 1 points to the remote gateway termination IP 1.1.1.2, while Site 2 points back to the Site 1 termination IP 1.1.1.1.
- **Peer Verification:** Set to any peer type with a robust Pre-Shared Key (PSK) string deployment to validate the cryptographic boundaries.
- **Interface Architecture:** net-device is explicitly disabled on both endpoints to support clean, route-based policy handling without spawning additional virtual interface nodes.
- **Cipher Suites & Negotiation Proposals:** The Phase 1 and Phase 2 architectures allow flexible but secure falling negotiations using standard Advanced Encryption Standard and Secure Hash Algorithm combinations:
 - aes128-sha256 / aes256-sha256 (*Primary*)
 - aes128-sha1 / aes256-sha1 (*Legacy Fallback*)

3.1.2 Production Configuration Blueprint (Sanitized)

Site 1 VPN Gateway Configuration:

```

config vpn ipsec phase1-interface
  edit "Site1-Site2"
    set interface "wan2"
    set peertype any
    set net-device disable
    set proposal aes128-sha256 aes256-sha256 aes128-sha1 aes256-sha1
    set comments "VPN: Site1-Site2 (Created by VPN wizard)"
    set wizard-type static-fortigate
    set remote-gw 1.1.1.2
    set psksecret ENC *****
  next
end

```

Site 2 VPN Gateway Configuration:

```

config vpn ipsec phase1-interface
  edit "Site2-Site1"
    set interface "wan2"
    set peertype any
    set net-device disable
    set proposal aes128-sha256 aes256-sha256 aes128-sha1 aes256-sha1
    set comments "VPN: Site2-Site1 (Created by VPN wizard)"
    set wizard-type static-fortigate
    set remote-gw 1.1.1.1
    set psksecret ENC *****
  next
end

```

3.1.3 Stateful Firewall Enforcement Policies

To permit traffic transit through the crypto engines, both firewalls deploy bidirectional matching policies to process networks mapped across the internal2 hardware interfaces:

Site 1 Inbound & Outbound Security Rules:

```
config firewall policy
  edit 2
    set name "vpn_Site1-Site2_local_0"
    set srcintf "internal2"
    set dstintf "Site1-Site2"
    set action accept
    set srcaddr "Site1-Site2_local"
    set dstaddr "Site1-Site2_remote"
    set schedule "always"
    set service "ALL"
    set comments "VPN: Site1-Site2 (Created by VPN wizard)"
  next
  edit 3
    set name "vpn_Site1-Site2_remote_0"
    set srcintf "Site1-Site2"
    set dstintf "internal2"
    set action accept
    set srcaddr "Site1-Site2_remote"
    set dstaddr "Site1-Site2_local"
    set schedule "always"
    set service "ALL"
    set comments "VPN: Site1-Site2 (Created by VPN wizard)"
  next
end
```

Site 2 Inbound & Outbound Security Rules:

```

config firewall policy
  edit 2
    set name "vpn_Site2-Site1_local_0"
    set srcintf "internal2"
    set dstintf "Site2-Site1"
    set action accept
    set srcaddr "Site2-Site1_local"
    set dstaddr "Site2-Site1_remote"
    set schedule "always"
    set service "ALL"
    set comments "VPN: Site2-Site1 (Created by VPN wizard)"
  next
  edit 3
    set name "vpn_Site2-Site1_remote_0"
    set srcintf "Site2-Site1"
    set dstintf "internal2"
    set action accept
    set srcaddr "Site2-Site1_remote"
    set dstaddr "Site2-Site1_local"
    set schedule "always"
    set service "ALL"
    set comments "VPN: Site2-Site1 (Created by VPN wizard)"
  next
end

```

3.2 Client-Based Remote Access SSL-VPN Architecture

To preserve off-site remote workforce connectivity while mitigating perimeter attack surfaces, an enterprise SSL-VPN termination gateway is operationalized on Site 1. Remote endpoints establish a secure transport tunnel utilizing the FortiClient endpoint application software.

3.2.1 Core Portal Settings & Ingress Rules

- **Ingress Interface Interface:** The gateway is bound explicitly to the untrusted public zone fabric via wan1, listening to inbound connections from any public source (all).
- **Non-Standard Port Binding:** Listening on TCP Port **8080** to minimize script-based scanning hits common on standard HTTPS/443 profiles.
- **Cryptographic Identity:** Secured via the explicit server certificate object ("SSL-VPN").
- **IP Allocation Mechanics:** Successful tunnel handshakes assign endpoints dynamic lease blocks from the pre-defined internal pool object ("SSLVPN_TUNNEL_ADDR1").
- **Role-Based Portal Mapping:** Default fallback connections route to a basic web-access portal; however, explicit authentication rules filter users matching the **VpnUser** group identity and provision a high-privilege full-access tunnel profile.

```

config vpn ssl settings
    set servercert "SSL-VPN"
    set tunnel-ip-pools "SSLVPN_TUNNEL_ADDR1"
    set tunnel-ipv6-pools "SSLVPN_TUNNEL_IPv6_ADDR1"
    set port 8080
    set source-interface "wan1"
    set source-address "all"
    set source-address6 "all"
    set default-portal "web-access"
    config authentication-rule
        edit 1
            set groups "VpnUser"
            set portal "full-access"
        next
    end
end

```

3.2.2 Tunnel Routing Verification Policy

When an authenticated remote user lands on the virtual root interface (ssl.root), explicit stateful inspection rule mechanisms restrict lateral movement. Policy edit 4 targets transit paths directed solely toward the secure engineering network segment (Site1-Site2_local_subnet_1) sitting behind the internal2 hardware zone. Network Address Translation (NAT) is enabled to mask remote user endpoints gracefully.

```

config firewall policy
    edit 4
        set name "VPN-Tunnel"
        set srcintf "ssl.root"
        set dstintf "internal2"
        set action accept
        set srcaddr "all"
        set dstaddr "Site1-Site2_local_subnet_1"
        set schedule "always"
        set service "ALL"
        set nat enable
        set groups "VpnUser"
    next
end

```

4. Centralized Logging Pipeline & Splunk Architecture

System visibility and timeline reconstruction require standard log telemetry centralization. A highly resilient logging pipeline was constructed using universal forwarders and standard syslogs.

4.1 Telemetry Collection Framework

The logging fabric feeds security telemetry directly to the Splunk Server (192.168.1.100) on dedicated ingress network ports:

- **Firewall Appliance Auditing:** FortiGate firewalls forward real-time logs via standardized UDP Port 514 syslog payloads, detailing address translation changes, stateful policy passes, and cryptographic tunnel disconnects.
- **Server OS Audit Trails:** The local DMZ Linux systems are installed with Splunk Universal Forwarder agents. Security metrics tracking authentication, system changes, and process forks are written continuously into monitored local flat-files (/var/log/auth.log and /var/log/syslog).
- **Web Service Traffic Recording:** The enterprise Apache application maps client interactions directly, allowing administrators to inspect request headers and malicious patterns by streaming out text objects continuously (/var/log/apache2/access.log and /var/log/apache2/error.log).

4.2 Splunk Data Parsing Configuration

To ensure clean searching capabilities and fast queries, incoming lines undergo strict schema categorization inside the index database definitions via the inputs.conf manifest file:

```
[monitor:///var/log/auth.log]
disabled = false
sourcetype = linux_secure
index = security_appliances

[monitor:///var/log/apache2/access.log]
disabled = false
sourcetype = access_combined
index = web_services
```

5. Empirical Cyber Attack Simulations & Diagnostic Analysis

To ensure our detection logic functions properly under threat conditions, an adversarial Kali Linux virtual machine was placed into the untrusted Public Zone fabric to execute automated multi-stage attacks against the Site 1 architecture.

5.1 Threat Vector A: Network Discovery and Reconnaissance (Nmap Port Scan)

Execution:

The threat actor initiated high-velocity reconnaissance profiling against the exposed public IP interfaces and DMZ boundaries. The scan aimed to discover live web components and exposed listening administration daemons.

```
kali# nmap -sS -p 22,80,443 -T4 -A -v 192.168.64.17
```

Parameters Used: -sS performs a stealthy TCP SYN half-open scan; -T4 accelerates the timing profile to trigger alert logic; -A forces OS fingerprinting and scanning scripts.

Splunk Detection & SPL Query Analysis:

The firewall recorded immediate TCP half-open connections hitting target zones within microsecond windows without finishing standard three-way handshakes. Security engineers can extract this reconnaissance footprint using Search Processing Language (SPL):

```
index=security_appliances sourcetype=fortigate_log action=blocked OR action=denied
| stats count BY src_ip, dest_port, action
```

```
| filter count > 100  
| rename src_ip AS "Attacker IP", dest_port AS "Target Port"
```

5.2 Threat Vector B: Authentication Brute-force Assault (SSH Credential Spraying)

Execution:

Following discovery of an active open port 22 hosting an OpenSSH server within the target environment, the adversary launched a brute force attack. This attack combined standard administrative user list variations with automated credential dictionary lists via the Hydra tool framework:

```
kali# ssh user@192.168.64.17
```

Splunk Detection & SPL Query Analysis:

Each incorrect attempt causes the PAM subsystem inside Linux to output a 'Failed password' entry line to the authentication log. This results in a massive surge of event logs within the SIEM container.

Threat Hunting SPL Diagnostic Signature

To isolate automated password spraying from accidental typo lockouts, analysts run a time-bucket aggregation calculation:

```
index=security_appliances sourcetype=linux_secure "Failed password"  
| bin _time span=1m  
| stats count, values(user) as attempted_users by _time, src_ip  
| where count > 20  
| rename src_ip as "Malicious Attacker Source"
```

6. Conclusion, Hardening Recommendations & Lessons Learned

6.1 Project Post-Mortem Analysis

The engineered enterprise network met all requirements listed in the capstone framework specification. The multi-zone layout successfully prevented direct access from the public zone to the internal local area network segments. Furthermore, the logging pipelines successfully fed detailed system metrics into the Splunk engine, allowing automated alerts to detect all simulated adversarial activity.

6.2 Infrastructure Hardening Plan

To protect against advanced threats that bypass standard perimeter firewalls, the following remediation tasks are recommended for immediate production rollout:

- **1. Enforce Multi-Factor Authentication (MFA):** Integrate the Client-Based SSL-VPN portal with time-based token services (such as Duo or Google Authenticator). This measure prevents attackers from compromising corporate infrastructure using compromised or brute-forced passwords alone.
- **2. Deploy Automated Host Controls (Fail2ban Integration):** Install defensive automation scripts on external-facing server nodes. These scripts parse local authentication failure thresholds and dynamically push temporary null-route firewall rules, blocking malicious attacker IPs at the local host level before they overwhelm system logs.

- **3. Transition to Next-Generation Deep Packet Inspection:** Configure application control profiling on FortiGate edge devices. This modification allows the firewalls to identify and block scanning tools based on behavioral signatures, moving beyond basic layer-4 port blocking rules.